# Ransomware Attack and Cryptography

Research -1

- أسم الهجمة ومجموعة التهديد : SafePay Ransomware Attack on Ingram Micro
- السنة : يوليو 2025
- الجهة المستهدفة : Ingram Micro وهي شركة توريد وتوزيع للأجهزة والبرامج من شركات تقنية كبرى حول العالم (مثل Apple و Cisco و Microsoft) للعديد من المتاجر والشركات الصغيرة اللي تعتمد عليها.
- أسلوب الهجوم : استغلوا بيانات مسروقة للدخول الى GlobalProtect VPN في شركة Ingram Micro لاعتماد بيانات دخول الموظفين عن بعد وما كان فيه مصادقة ثنائية و قدروا يوصلون الى حساب بصلاحيات مرتفعة بعد الدخول المستخدمة ووقفوا خدمات قواعد البيانات وبرامج النسخ الاحتياطي زي Veeam عشان يقطعون أي طريقة يسترجعون فيها الضحية ملفاته بدون ما يدفعون الفدية ونشروا برمجية Safepay والبرمجية تسوي تشفير عشوائي لكل ملف منفصل عن الثاني باستخدام ChaCha 20 وبعدها ياخذون المفتاح و يشفرونه باستخدام المفتاح العام حق المهاجم باستخدام RSA والمفتاح الخاص ينحفظ في جهاز المهاجم فقط وهو المفتاح الوحيد اللي تقدر تفك تشفير مفتاح ChaCha20 وبكذا مايقدر الضحية يفك أي ملف حتى لو وصل للمفتاح العام اللي داخل البرمجية لان الفك يحتاج المفتاح الخاص بس و موجود عند المهاجم بس .
- الأثر الناتج عن الهجمة : تعطلت منصة xvantage وهي المنصة المسؤوله عن الطلبات والشحن والتوقف استمر لعدة أيام والتأثير وصل عالميا لان شركة Ingram Micro توزع آلاف المحلات والشركات حول العالم واضطروا يعزلون بعض الانظمة الاخرى كإجراء احترازي و استرجعوا الأنظمة بشكل تدريجي ورجعوا لنسخ احتياطية غير متأثرة بالهجوم اللي صار ورجعت الانظمة بشكل كامل بعد اسبوع تقريبا من الهجوم والمهاجم هدد بنشر بيانات بحجم 3.5 تيرابايت على الدارك ويب ولم تتجاوب معه الشركة وبعدها تم تأكيد تسريب بيانات أكثر من 42000 موظف .
- المصدر :

https://www.bleepingcomputer.com/news/security/safepay-ransomware-threatens-to-leak-35tb-of-ingram-micro-data

https://www.picussecurity.com/resource/blog/inside-safepay-analyzing-the-new-centralized-ransomware-group

---

- أسم الهجمة ومجموعة التهديد: Akira Ransomware Attack
- السنة : مارس 2023
- الجهة المستهدفة : شركات متنوعة بمجالات مختلفة زي التقنية والتصنيع والرعاية الصحية والتعليم و ما استهدفت شركة وحدة بعينها بل عشرات الشركات حول العالم بقطاعات متعددة من أبرز ضحاياها جامعة Stanford وشركة Nissan في استراليا و شركة Tietoevry .
- أسلوب الهجوم : دخلت مجموعة Akira الشبكة عن طريق استغلال ثغرات غير محدثة في VPN معروفة بأجهزة Cisco واستغلوا الثغرات CVE-2020-3259 و CVE-2023-20269 وبعد الدخول استخدموا أداة Mimikatz لاستخراج كلمات المرور الموجودة في ذاكرة النظام وايضا أنشأوا حسابات جديدة لضمان بقاء وصولهم وعطلوا برامج الحماية وتحركوا بين الاجهزة داخل الشبكة. بعدها شغلوا ملف Akira مكتوب بلغة C++ و النسخة الأحدث Megazord المكتوبة بـ Rust وتستهدف أنظمة Linux والبرمجية تولد مفتاح IV عشوائي وتستخدمهم لتشفير كل ملف لحاله بخوارزمية ChaCha20 وبعدها تاخذ هذا المفتاح وتشفره باستخدام مفتاح RSA عام بطول 4096 بت مضمن جوا البرمجية و المفتاح الخاص هو المفتاح الوحيد اللي يقدر يفك تشفير مفتاح ChaCha20 وكذا ما يقدر الضحية يفك أي ملف حتى لو وصل للمفتاح العام اللي داخل البرمجية. وفي الملفات الكبيرة جدا زي ملفات vmdk يسوون تشفير جزئي بس لاجزاء محددة من الملف عشان يسرعون العملية.
- الأثر الناتج عن الهجمة : أكثر من 250 منظمة تأثرت بحلول بداية 2024 وتوسع العدد لاحقا حسب تقرير مشترك من جهات حكومية أمريكية وفرنسية وألمانية وهولندية ومن أبرز الضحايا جامعة Stanford اللي اخترق المهاجمون قسم الأمن الجامعي فيها لأكثر من 4 أشهر بدون ما يكتشفونهم من مايو إلى سبتمبر 2023 وسرقوا 430 جيجابايت بيانات شملت ارقام ضمان اجتماعي وجوازات سفر لـ 27 الف شخص والجامعة ما دفعت الفدية فنشر المهاجمون البيانات فعليا على الدارك ويب كملف قابل للتحميل وشركة Nissan استراليا سرقوا منها المهاجمون 100 جيجابايت بيانات ومشاريع وعملاء واتفاقيات سرية أثرت على حوالي 100 ألف شخص وانكشفت لبعضهم وثائق هوية رسمية والشركة رفضت دفع الفدية من الاساس وحتى الان ما فيه أداة فك تشفير علنية متاحة لضحايا النسخ الحديثة من Akira والمجموعة لسا نشطة بقوة لين الان.
- المصدر :

https://www.trendmicro.com/vinfo/us/security/news/ransomware-spotlight/ransomware-spotlight-akira

https://www.securityweek.com/akira-ransomware-group-made-244-million-in-ransom-proceeds/

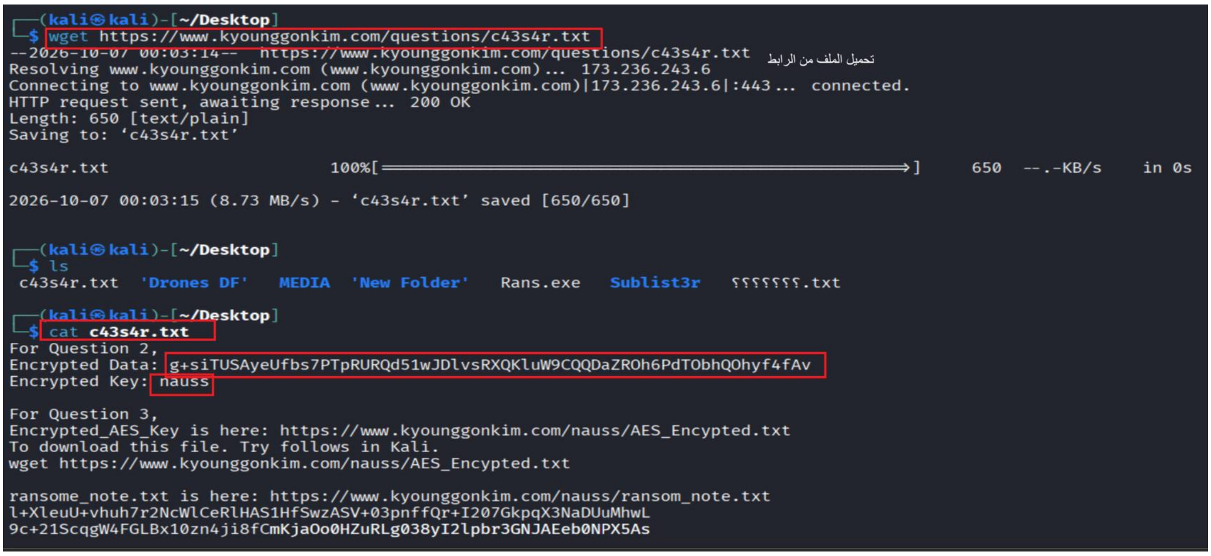
- أسم الهجمة ومجموعة التهديد : ALPHV/BlackCat Ransomware Attack
- السنة : فبراير 2024
- الجهة المستهدفة : Change Healthcare وهي شركة معالجة مدفوعات ومطالبات طبية في قطاع الرعاية الصحية الأمريكي تربط بين المستشفيات والصيدليات وشركات التأمين لمعالجة الفواتير والمطالبات .
- أسلوب الهجوم: استغلوا بيانات دخول مسروقة لحساب Citrix للوصول عن بعد وما كانت محمية بمصادقة ثنائية وبعد الدخول صعدوا صلاحياتهم عن طريق استغلال مكون COM موثوق بويندوز يشغل برامج بصلاحيات أدمن بدون ما يطلب موافقة من نافذة UAC وبكذا تجاوزوا الحماية وتحركوا داخل الشبكة لمدة 9 أيام تقريبا قبل ما يبدأون التشفير وسرقوا كميات ضخمة من البيانات خلال هالفترة وبعدها شغلوا برمجية BlackCat المكتوبة بلغة Rust والبرمجية تولد مفتاح AES عشوائي لكل ملف باستخدام دالة BCryptGenRandom وهي دالة  تولد أرقام عشوائية غير قابلة للتخمين وتنشئ ملف JSON صغير لكل ملف مشفر فيه مفتاحه ومعلومات تعريفية عنه وبعدها تشفر مفتاح AES نفسه باستخدام مفتاح RSA عام مخزن داخل إعدادات البرمجية والمفتاح الخاص موجود بس عند المهاجم وهو الوحيد اللي يقدر يفك مفاتيح AES.
- الأثر الناتج عن الهجمة : دفعت فدية بقيمة 22 مليون دولار لمجموعة ALPHV/BlackCat مقابل مفتاح فك التشفير ووعد بعدم تسريب البيانات ولكن المجموعة تشتغل بنظام RaaS يعني هم يطورون البرمجية ويبيعونها على اشخاص او مجموعات ثانية مثل مجموعة RansomHub وهم اللي فعلا دخلوا على الشبكة وسرقوا البيانات باستخدام هذه الاداة ولكن بعد دفع الفدية لمجموعة ALPHV/BlackCat  اختفوا ولا أعطوا مجموعة RansomHub  النسبة المتفق بينهم فرجعت مجموعة RansomHub وهددوا الشركة Change Healthcare  لدفع فدية لهم ولكن الشركة ماتجاوبت وسربوا بيانات أكثر من 190 مليون شخص من المرضى والفواتير وتفاصيل العلاج ونشرها على الدارك ويب وتعطلت عمليات صرف الادوية ومعالجة المطالبات الطبية لاكثر من اسبوع كامل في الاف المستشفيات والصيدليات وتعتبر من أكبر تسريب البيانات الصحية في امريكا وكلفت الشركة أكثر من 2.4 مليار دولار .
- المصدر :

https://www.bankinfosecurity.com/ransomhub-claims-a-24803

https://www.securityweek.com/second-ransomware-group-extorting-change-healthcare/

## Practical Cryptography -2

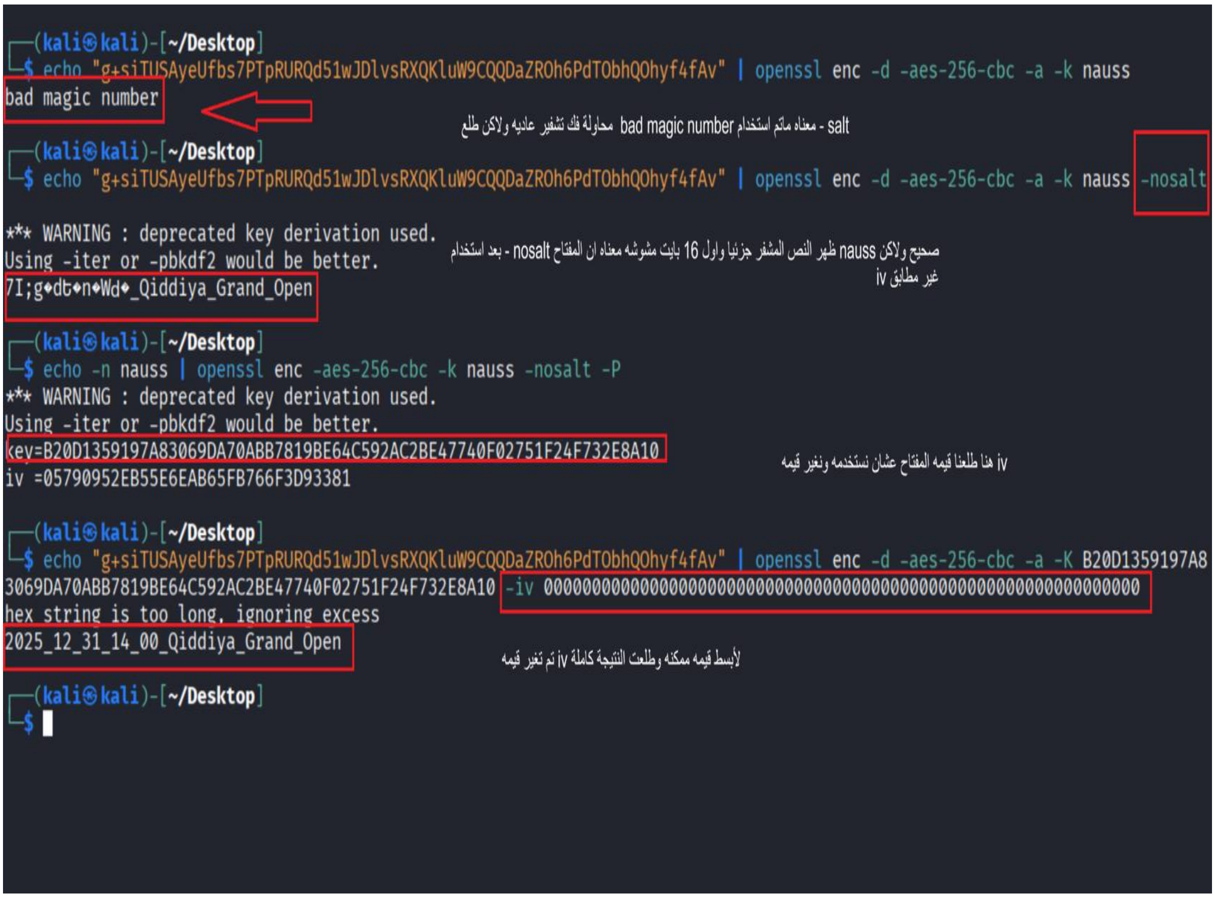
- نوع التشفير : AES-256-CBC تشفير متماثل بصيغة Base64 بدون Salt
- دور nauss: كلمة سر يشتق منها مفتاح AES تلقائيا لازم لفك التشفير.
- الأداة: openssl enc -d -aes-256-cbc -a -k nauss -nosalt
- الناتج : Qiddiya_Grand_Open_00_14_31_12_2025



```
┌──(kali㉿kali)-[~/Desktop]
└─$ wget https://www.kyounggonkim.com/questions/c43s4r.txt
--2026-10-07 00:03:14--  https://www.kyounggonkim.com/questions/c43s4r.txt
Resolving www.kyounggonkim.com (www.kyounggonkim.com)... 173.236.243.6
Connecting to www.kyounggonkim.com (www.kyounggonkim.com)|173.236.243.6|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 650 [text/plain]
Saving to: ‘c43s4r.txt’

c43s4r.txt                 100%[=====================================================>]     650  --.-KB/s    in 0s

2026-10-07 00:03:15 (8.73 MB/s) - ‘c43s4r.txt’ saved [650/650]
```

تحميل الملف من الرابط

```
┌──(kali㉿kali)-[~/Desktop]
└─$ ls
 c43s4r.txt  'Drones DF'   MEDIA  'New Folder'   Rans.exe   Sublist3r   ؟؟؟؟؟؟؟.txt

┌──(kali㉿kali)-[~/Desktop]
└─$ cat c43s4r.txt
For Question 2,
Encrypted Data: g+siTUSAyeUfbs7PTpRURQd51wJDlvsRXQKluW9CQQDaZROh6PdTObhQOhyf4fAv
Encrypted Key: nauss

For Question 3,
Encrypted_AES_Key is here: https://www.kyounggonkim.com/nauss/AES_Encypted.txt
To download this file. Try follows in Kali.
wget https://www.kyounggonkim.com/nauss/AES_Encypted.txt

ransome_note.txt is here: https://www.kyounggonkim.com/nauss/ransom_note.txt
l+XleuU+vhuh7r2NcWlCeRlHAS1HfSwzASV+03pnffQr+I207GkpqX3NaDUuMhwL
9c+21ScqgW4FGLBx10zn4ji8fCmKjaOo0HZuRLg038yI2lpbr3GNJAEeb0NPX5As
```



```
┌──(kali㉿kali)-[~/Desktop]
└─$ echo "g+siTUSAyeUfbs7PTpRURQd51wJDlvsRXQKluW9CQQDaZROh6PdTObhQOhyf4fAv" | openssl enc -d -aes-256-cbc -a -k nauss
bad magic number
```

- salt معناه ماتم استخدام bad magic number محاولة فك تشفير عاديه ولاكن طلع

```
┌──(kali㉿kali)-[~/Desktop]
└─$ echo "g+siTUSAyeUfbs7PTpRURQd51wJDlvsRXQKluW9CQQDaZROh6PdTObhQOhyf4fAv" | openssl enc -d -aes-256-cbc -a -k nauss -nosalt

*** WARNING : deprecated key derivation used.
Using -iter or -pbkdf2 would be better.
7I;g◆dt◆n◆Wd◆_Qiddiya_Grand_Open
```

صحيح ولاكن nauss ظهر النص المشفر جزئيا واول 16 بايت مشوشه معناه ان المفتاح nosalt - بعد استخدام
غير مطابق iv

```
┌──(kali㉿kali)-[~/Desktop]
└─$ echo -n nauss | openssl enc -aes-256-cbc -k nauss -nosalt -P
*** WARNING : deprecated key derivation used.
Using -iter or -pbkdf2 would be better.
key=B20D1359197A83069DA70ABB7819BE64C592AC2BE47740F02751F24F732E8A10
iv =05790952EB55E6EAB65FB766F3D93381
```

iv هنا طلعنا قيمه المفتاح عشان نستخدمه ونغير قيمه

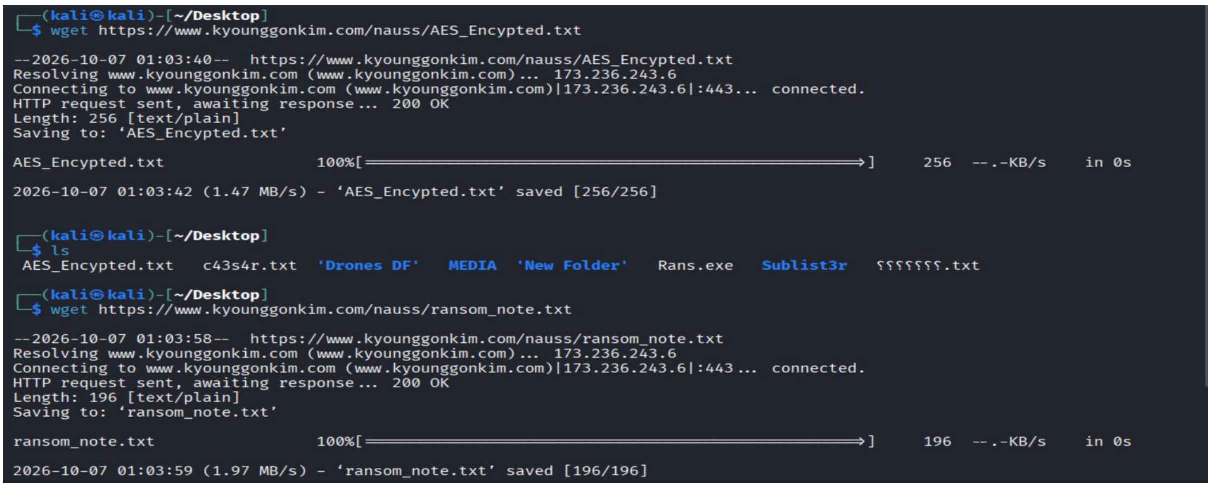
```
┌──(kali㉿kali)-[~/Desktop]
└─$ echo "g+siTUSAyeUfbs7PTpRURQd51wJDlvsRXQKluW9CQQDaZROh6PdTObhQOhyf4fAv" | openssl enc -d -aes-256-cbc -a -K B20D1359197A8
3069DA70ABB7819BE64C592AC2BE47740F02751F24F732E8A10 -iv 00000000000000000000000000000000000000000000000000000000000000
hex string is too long, ignoring excess
2025_12_31_14_00_Qiddiya_Grand_Open

┌──(kali㉿kali)-[~/Desktop]
└─$ ▌
```

لأبسط قيمه ممكنه وطلعت النتيجة كاملة iv تم تغير قيمه

# Ransomware Practical Analysis AES + RSA -3

- تحميل الملف : الأمر

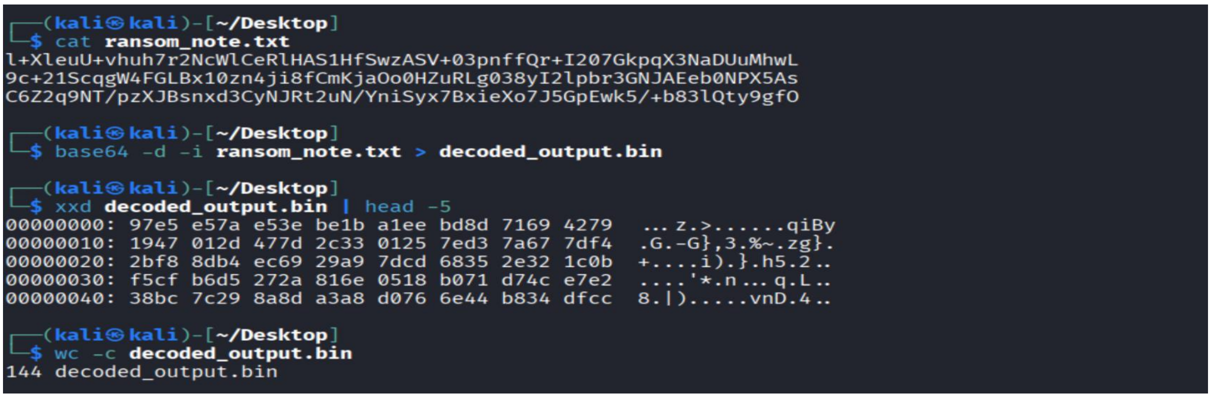
wget https://www.kyounggonkim.com/nauss/ransom_note.txt



```
┌──(kali㉿kali)-[~/Desktop]
└─$ wget https://www.kyounggonkim.com/nauss/AES_Encypted.txt

--2026-10-07 01:03:40--  https://www.kyounggonkim.com/nauss/AES_Encypted.txt
Resolving www.kyounggonkim.com (www.kyounggonkim.com)... 173.236.243.6
Connecting to www.kyounggonkim.com (www.kyounggonkim.com)|173.236.243.6|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 256 [text/plain]
Saving to: 'AES_Encypted.txt'

AES_Encypted.txt            100%[===================================================>]     256  --.-KB/s    in 0s

2026-10-07 01:03:42 (1.47 MB/s) - 'AES_Encypted.txt' saved [256/256]


┌──(kali㉿kali)-[~/Desktop]
└─$ ls
 AES_Encypted.txt   c43s4r.txt  'Drones DF'   MEDIA  'New Folder'   Rans.exe   Sublist3r   ؟؟؟؟؟؟؟.txt

┌──(kali㉿kali)-[~/Desktop]
└─$ wget https://www.kyounggonkim.com/nauss/ransom_note.txt

--2026-10-07 01:03:58--  https://www.kyounggonkim.com/nauss/ransom_note.txt
Resolving www.kyounggonkim.com (www.kyounggonkim.com)... 173.236.243.6
Connecting to www.kyounggonkim.com (www.kyounggonkim.com)|173.236.243.6|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 196 [text/plain]
Saving to: 'ransom_note.txt'

ransom_note.txt             100%[===================================================>]     196  --.-KB/s    in 0s

2026-10-07 01:03:59 (1.97 MB/s) - 'ransom_note.txt' saved [196/196]
```

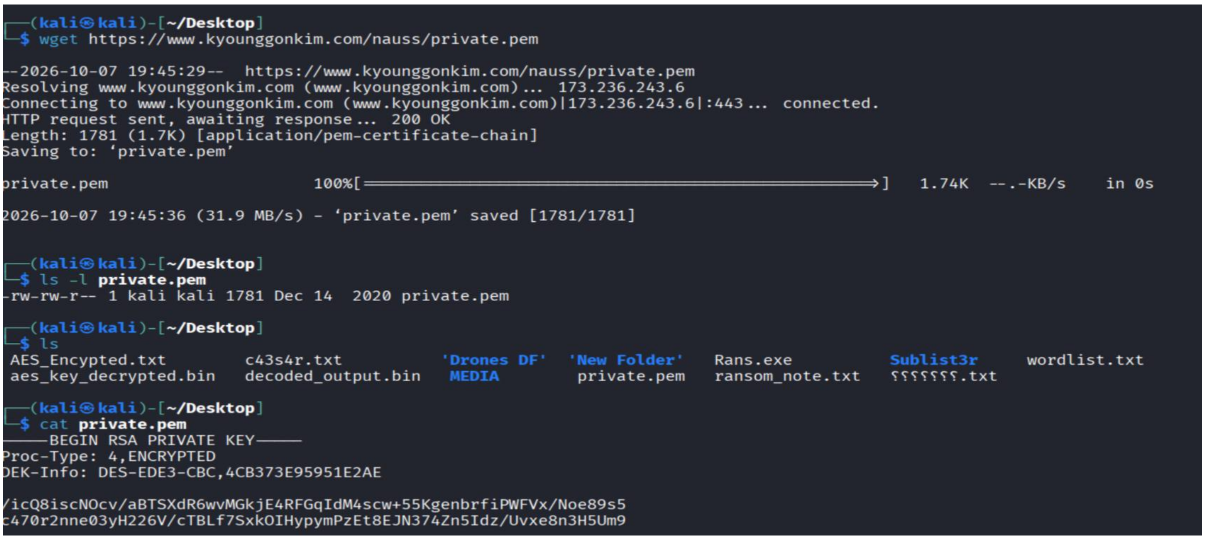
- مانوع التشفير المستخدم لحماية مفتاح AES ولماذا لايمكن استخدامه لفك التشفير ؟
- تم تشفير مفتاح AES باستخدام RSA وعرفت ذلك بسبب أن محتوى الملف بيانات ثنائية خام مو نص Base64 زي باقي الملفات وهذا يختلف عن ملفات AES العادية اللي تطلع بصيغة Base64 مقروءة وهذا الاختلاف بالشكل يدعم ان نوع التشفير RSA ولا يمكن استخدامه مباشرة لفك التشفير لان الملف نفسه مفتاح AES مشفر مو جاهز للاستخدام ويحتاج المفتاح الخاص RSA الموجود في https://www.kyounggonkim.com/nauss/private.pem

- تحميل ملف ransom_note.txt وماهو نوع البيانات داخل هذا الملف وهل هو نص مقروء؟
- حملت الملف ولاحظت ان محتواه نص بصيغة Base64 حروف كبيرة وصغيرة وأرقام ورموز وتأكدنا من هذا بأمر ونجح فك الترميز وطلع ملف ثنائي حجمه 144 بايت وهذا الحجم يتوافق مع تشفير AES-CBC بخصوص هل هو نص مقروء فلا الشكل الظاهر Base64 قابل للعرض لكن المحتوى الحقيقي خلفه بيانات عشوائية مشفرة بـ AES تحتاج فك تشفير فعلي مو مجرد فك الترميز.

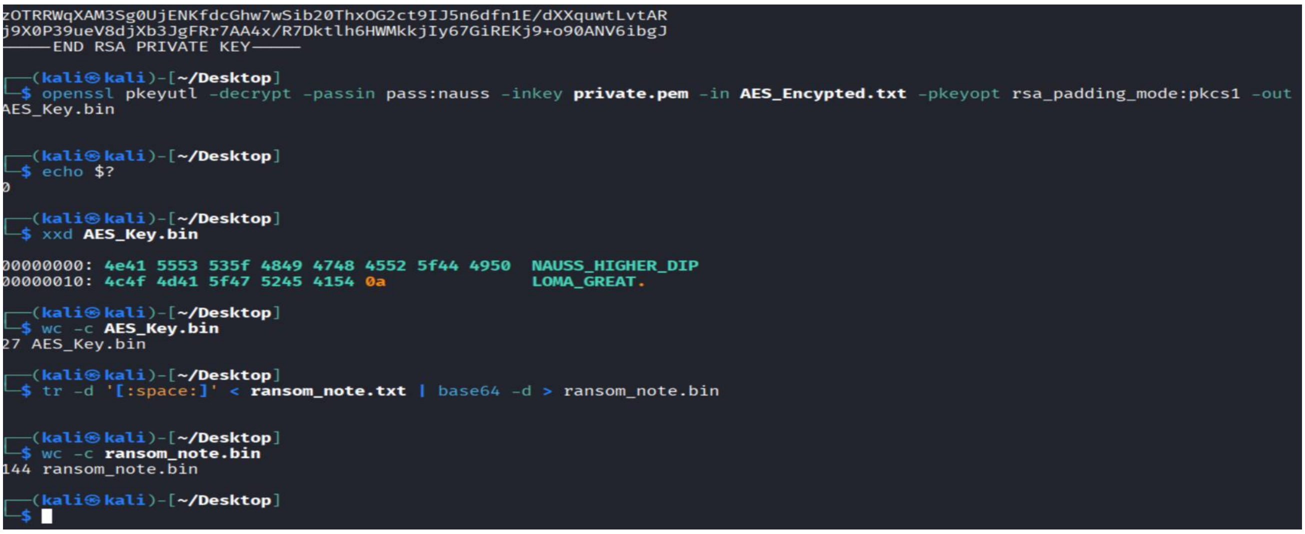


```
┌──(kali㉿kali)-[~/Desktop]
└─$ cat ransom_note.txt
l+XleuU+vhuh7r2NcWlCeRlHAS1HfSwzASV+03pnffQr+I207GkpqX3NaDUuMhwL
9c+21ScqgW4FGLBx10zn4ji8fCmKjaOo0HZuRLg038yI2lpbr3GNJAEeb0NPX5As
C6Z2q9NT/pzXJBsnxd3CyNJRt2uN/YniSyx7BxieXo7J5GpEwk5/+b83lQty9gfO

┌──(kali㉿kali)-[~/Desktop]
└─$ base64 -d -i ransom_note.txt > decoded_output.bin

┌──(kali㉿kali)-[~/Desktop]
└─$ xxd decoded_output.bin | head -5
00000000: 97e5 e57a e53e be1b a1ee bd8d 7169 4279  ...z.>......qiBy
00000010: 1947 012d 477d 2c33 0125 7ed3 7a67 7df4  .G.-G},3.%~.zg}.
00000020: 2bf8 8db4 ec69 29a9 7dcd 6835 2e32 1c0b  +....i).}.h5.2..
00000030: f5cf b6d5 272a 816e 0518 b071 d74c e7e2  ....'*.n...q.L..
00000040: 38bc 7c29 8a8d a3a8 d076 6e44 b834 dfcc  8.|).....vnD.4..

┌──(kali㉿kali)-[~/Desktop]
└─$ wc -c decoded_output.bin
144 decoded_output.bin
```

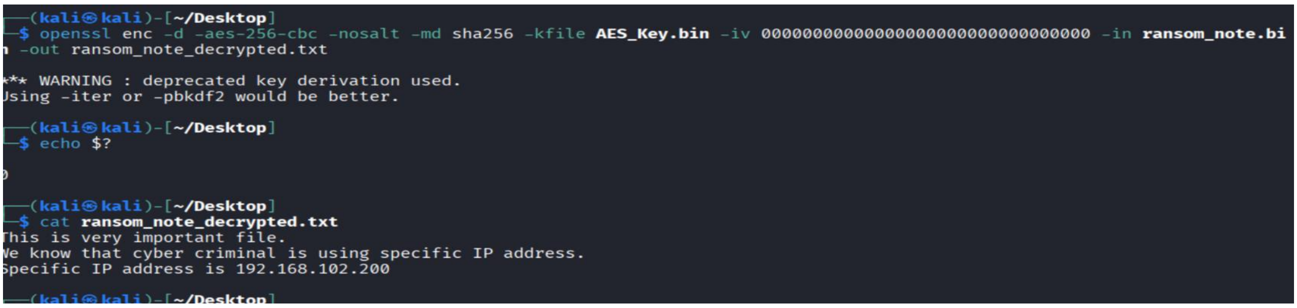
- شرح الخطوات العامه بدون اوامر :
- نستخدم المفتاح الخاص لـ RSA عشان نفك تشفير ملف AES_Encrypted.txt ونستخرج منه مفتاح AES. بعدها نفك ترميز Base64 عن ملف ransom_note.txt للحصول على البيانات المشفرة الفعلية وناخذ مفتاح AES الناتج من الخطوة الأولى ونستخدمه لفك تشفير هذي البيانات فيرجع لنا محتوى الرسالة الأصلي .



```
┌──(kali㉿kali)-[~/Desktop]
└─$ wget https://www.kyounggonkim.com/nauss/private.pem

--2026-10-07 19:45:29--  https://www.kyounggonkim.com/nauss/private.pem
Resolving www.kyounggonkim.com (www.kyounggonkim.com)... 173.236.243.6
Connecting to www.kyounggonkim.com (www.kyounggonkim.com)|173.236.243.6|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1781 (1.7K) [application/pem-certificate-chain]
Saving to: ‘private.pem’

private.pem                 100%[==================================>]   1.74K  --.-KB/s    in 0s

2026-10-07 19:45:36 (31.9 MB/s) - ‘private.pem’ saved [1781/1781]


┌──(kali㉿kali)-[~/Desktop]
└─$ ls -l private.pem
-rw-rw-r-- 1 kali kali 1781 Dec 14  2020 private.pem

┌──(kali㉿kali)-[~/Desktop]
└─$ ls
 AES_Encypted.txt        c43s4r.txt           'Drones DF'  'New Folder'   Rans.exe          Sublist3r    wordlist.txt
 aes_key_decrypted.bin   decoded_output.bin    MEDIA         private.pem   ransom_note.txt   ؟؟؟؟؟؟؟.txt

┌──(kali㉿kali)-[~/Desktop]
└─$ cat private.pem
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4,ENCRYPTED
DEK-Info: DES-EDE3-CBC,4CB373E95951E2AE

/icQ8iscNOcv/aBTSXdR6wvMGkjE4RFGqIdM4scw+55KgenbrfiPWFVx/Noe89s5
c470r2nne03yH226V/cTBLf7SxkOIHypymPzEt8EJN374Zn5Idz/Uvxe8n3H5Um9
```



```
zOTRRWqXAM3Sg0UjENKfdcGhw7wSib20ThxOG2ct9IJ5n6dfn1E/dXXquwtLvtAR
j9X0P39ueV8djXb3JgFRr7AA4x/R7Dktlh6HWMkkjIy67GiREKj9+o90ANV6ibgJ
-----END RSA PRIVATE KEY-----

┌──(kali㉿kali)-[~/Desktop]
└─$ openssl pkeyutl -decrypt -passin pass:nauss -inkey private.pem -in AES_Encypted.txt -pkeyopt rsa_padding_mode:pkcs1 -out
AES_Key.bin


┌──(kali㉿kali)-[~/Desktop]
└─$ echo $?
0

┌──(kali㉿kali)-[~/Desktop]
└─$ xxd AES_Key.bin

00000000: 4e41 5553 535f 4849 4748 4552 5f44 4950  NAUSS_HIGHER_DIP
00000010: 4c4f 4d41 5f47 5245 4154 0a              LOMA_GREAT.

┌──(kali㉿kali)-[~/Desktop]
└─$ wc -c AES_Key.bin
27 AES_Key.bin

┌──(kali㉿kali)-[~/Desktop]
└─$ tr -d '[:space:]' < ransom_note.txt | base64 -d > ransom_note.bin


┌──(kali㉿kali)-[~/Desktop]
└─$ wc -c ransom_note.bin
144 ransom_note.bin

┌──(kali㉿kali)-[~/Desktop]
└─$ ▮
```



```
┌──(kali㉿kali)-[~/Desktop]
└─$ openssl enc -d -aes-256-cbc -nosalt -md sha256 -kfile AES_Key.bin -iv 00000000000000000000000000000000 -in ransom_note.bi
n -out ransom_note_decrypted.txt

*** WARNING : deprecated key derivation used.
Using -iter or -pbkdf2 would be better.

┌──(kali㉿kali)-[~/Desktop]
└─$ echo $?

0

┌──(kali㉿kali)-[~/Desktop]
└─$ cat ransom_note_decrypted.txt
This is very important file.
We know that cyber criminal is using specific IP address.
Specific IP address is 192.168.102.200

┌──(kali㉿kali)-[~/Desktop]
```

- لماذا تستخدم Ransomware تشفير متماثل AES لتشفير الملفات و تشفير غير متماثل RSA لحماية المفتاح ؟
- لأن AES سريع جدا لتشفير كميات ضخمة من الملفات بوقت قصير لكن مشكلته يستخدم مفتاح واحد فقط و يشفرون هذا المفتاح باستخدام RSA مو الملفات كلها عشان محد يقدر يفك المفتاح لان المفتاح الخاص موجود عند المهاجم فيجمعون بين الاثنين (AES للسرعة تشفير الملفات + RSA للحماية المفتاح الخاص بتشفير الملفات ).

---

الأسم : رياض سلطان الشهري
الجامعة : أم القرى
المؤهل العلمي : هندسة الحاسب الآلي